

课程内容提要

希赛

- 信息安全基础（★★）
- 信息加解密技术（★★★）
- 密钥管理技术（★★）
- 访问控制及数字签名技术（★★★）
- 信息安全的保障体系



信息安全基础

希赛

◆ 信息安全包括5个基本要素：

名称	说明
机密性	机密性是指网络信息不泄露给非授权的用户、实体或程序，能够防止非授权者获取信息。
完整性	完整性是指网络信息或系统未经授权不能进行更改的特性。
可用性	可用性是指合法许可的用户能够及时获取网络信息或服务的特性。
可控性	可控性是指可以控制授权范围内的信息流向及行为方式。
可审查性	可审查性是指对出现的信息安全问题提供调查的依据和手段。

CIA

五要素

信息安全的范围包括设备安全、数据安全、内容安全和行为安全。



- **网络安全漏洞**

安全隐患主要表现如下：

1、物理安全性。

2、软件安全漏洞。

3、不兼容使用安全漏洞。

4、选择合适的安全哲理。



◆ **网络安全威胁**

网络安全威胁主要表现形式如下：

1、非授权访问。

2、信息泄露或丢失。 敏感类型信息，密码等。

3、破坏数据完整性。

4、拒绝服务攻击。 破坏可用性。

5、利用网络传播病毒。

◆ **安全措施的目标**

安全措施的目标如下：

1、访问控制。

2、认证。

3、完整性。

4、审计。

5、保密。



习题讲解

希赛

在进行软件系统安全性分析时，（ ）保证信息不泄露给未授权的用户、实体或过程；完整性保证信息的完整和准确，防止信息被非法修改；（ ）保证对信息的传播及内容具有控制的能力，防止为非法者所用。

A. 完整性　　B. 不可否认性　　C. 可控性　　D. 机密性

A. 完整性　　B. 安全审计　　C. 加密性　　D. 可控性

安全性是根据系统可能受到的安全威胁的类型来分类的。其中，（ ）保证信息不泄露给未授权的用户、实体或过程；（ ）保证信息的完整和准确，防止信息被篡改。

A. 可控性　　B. 机密性　　C. 安全审计　　D. 健壮性

A. 可控性　　B. 完整性　　C. 不可否认性　　D. 安全审计

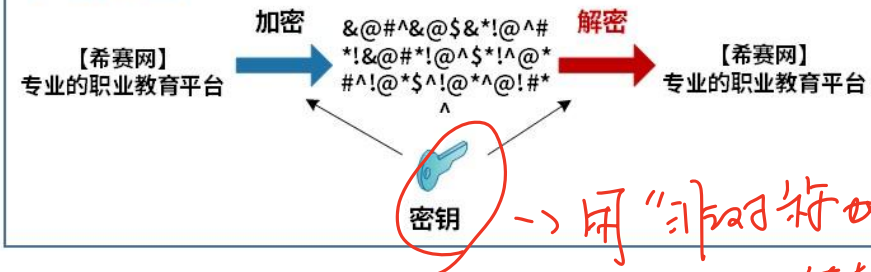


信息加解密技术

希赛

传输时的机密性。

【对称加密】



【特点】

1、加密强度不高，但效率高，易破解。

2、密钥分发困难。

用"非对称加密"传输"密钥"。

不安全

【非对称加密】



【特点】

1、加密强度高，但效率低，极难破解。

2、密钥分发容易。

安全

加快速度

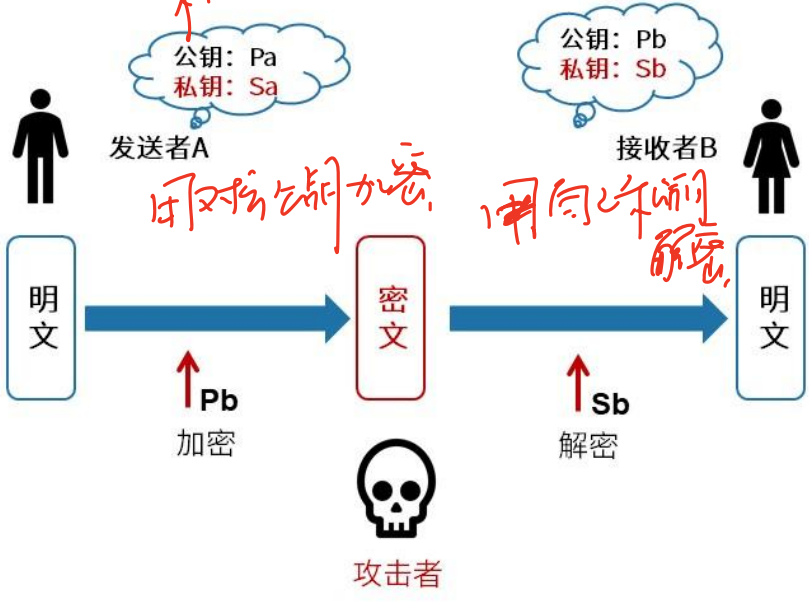


信息加解密技术

希赛

【游戏规则】

任何人的【私钥】，只有自己拥有
任何人的【公钥】，可以明文公开发送





信息加解密技术

希赛

对称加密算法【共享密钥】	非对称加密算法【公开密钥】
【用途】对消息明文进行加密传送	【用途】：对密钥加密，做数字签名
☐ DES：替换+移位、56位密钥、64位数据块、速度快、密钥易产生 ☐ 3DES(三重DES) 密钥长度112【两个56位的密钥K1、K2】 加密：K1加密->K2解密->K1加密 解密：K1解密->K2加密->K1解密 ☐ IDEA：128位密钥、64位明文/密文，PGP ☐ 其它对称加密算法：RC-5、AES	■ RSA：2048位（或1024位）密钥 ■ Elgamal：安全性依赖于计算有限域上离散对数这一难题 ■ ECC：椭圆曲线算法 ■ Diffie-Hellman



习题讲解

希赛

一个密码系统至少由明文、密文、加密算法、解密算法和密钥五个部分组成，而其安全性是由（ ）决定的。

A. 加密算法　　B. 解密算法

C. 加解密算法　　D. 密钥

利用公开密钥算法进行数据加密时，采用的方式是（ ）。

A．发送方用公开密钥加密，接收方用公开密钥解密

B．发送方用私有密钥加密，接收方用私有密钥解密

C．发送方用公开密钥加密，接收方用私有密钥解密

D．发送方用私有密钥加密，接收方用公开密钥解密



习题讲解

公司总部与分部之间需要传输大量数据，在保障数据安全的同时又要兼顾密钥算法效率，最合适的加密算法是（ ）。

A．RC-5

B．RSA

C．ECC

D．MD5



访问控制技术

希赛

访问控制的基本模型

访问控制的目标有两个：

- 防止非法用户进入系统；
- 阻止合法用户对系统资源的非法使用，即禁止合法用户的越权访问。

访问控制的三要素：

- **主体：** 可以对其他实体施加动作的主动实体，记为S；
- **客体：** 是接受其他实体访问的被动实体，记为O；
- **控制策略：** 是主体对客体的操作行为集和约束条件集，记为KS。



访问控制技术

希赛

- **访问控制的实现技术**

访问控制矩阵（ACM）：矩阵中的每一格表示所在行的主体对所在列的客体的访问授权。

	file1	file2	file3
User1	rw		rw
User2	r	rwx	x
User3	x	r	

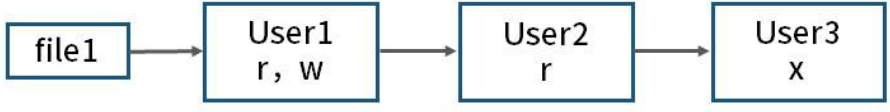


访问控制技术

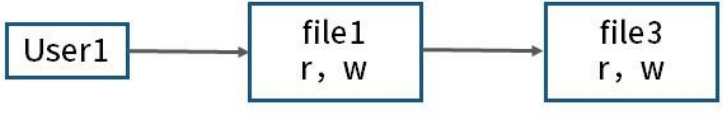
希赛

- **访问控制的实现技术**

访问控制列表：访问控制矩阵按列分解，具体如下：



能力表：访问控制矩阵按行分解，具体如下：



授权关系表：对应访问矩阵中每一个非空元素的实现技术。像安全数据库系统通常用授权关系表来实现其访问控制安全机制。



数字签名技术

希赛

信息摘要：单向散列函数【不可逆】、固定长度的散列值。

摘要用途：确保信息【完整性】，防篡改。



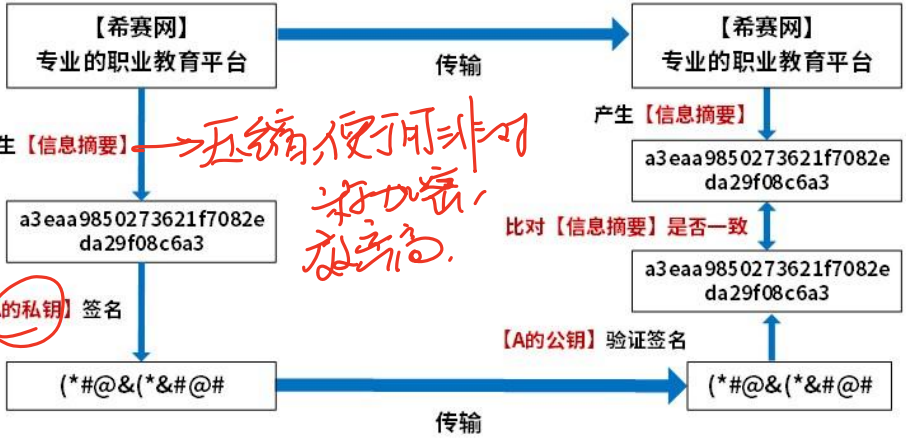
常用的消息摘要算法有MD5，SHA等，市场上广泛使用的MD5，SHA算法的散列值分别为128和160位，由于SHA通常采用的密钥长度较长，因此安全性高于MD5。



数字签名技术

希赛

数字签名过程分析





练习题

希赛

请依据已学习的加密解密技术，以及信息摘要，数字签名技术解决以下问题：

请设计一个安全邮件传输系统，要求：

该邮件以加密方式传输，邮件最大附件内容可达2GB，发送者不可抵赖，若邮件被第三方截获，第三方无法篡改。

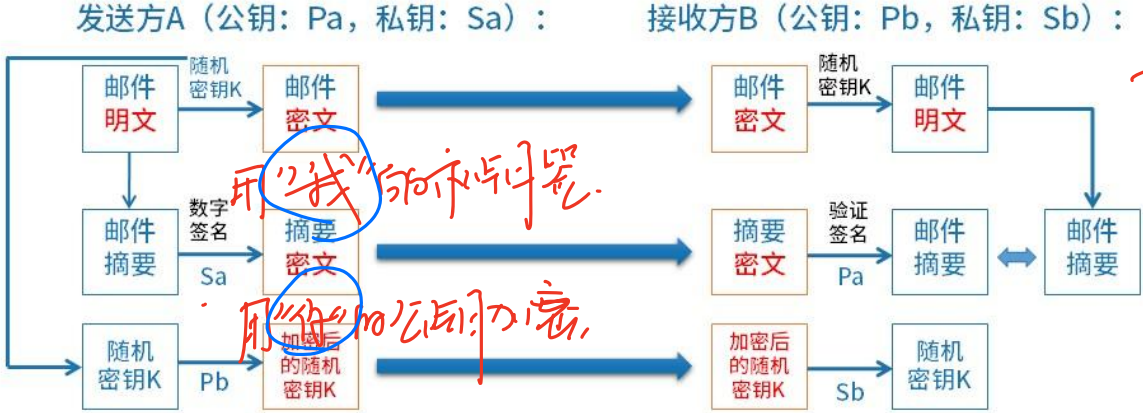


练习题

加密解密技术　　对称加密　　数字签名

该邮件以加密方式传输，邮件最大附件内容可达2GB，发送者不可抵赖，若邮件被第三方截获，第三方无法篡改。

信息摘要技术





习题讲解

希赛

以下属于访问控制的目标的是（ ）。

A. 防止非法用户进入系统　　B. 防止病毒进入系统

C. 防止内网用户访问外网　　D. 防止外网用户访问内网

数字签名最常见的实现方法是建立在（ ）的组合基础之上。

A．公钥密码体制和对称密码体制

B．对称密码体制和MD5摘要算法

C．公钥密码体制和单向安全散列函数算法

D．公证系统和MD4摘要算法



习题讲解

数字签名首先需要生成消息摘要，然后发送方用自己的私钥对报文摘要进行加密，接收方用发送方的公钥验证真伪。生成消息摘要的目的是（ ），对摘要进行加密的目的是（ ）。

A．防止窃听　　B．防止抵赖　　C．防止篡改　　D．防止重放

A．防止窃听　　B．防止抵赖　　C．防止篡改　　D．防止重放



密钥管理技术

希赛

◆ 数字证书内容

- 证书的版本信息；
- 证书的序列号，每个证书都有一个唯一的证书序列号；
- 证书所使用的签名算法；
- 证书的发行机构名称，命名规则一般采用X.500格式；
- 证书的有效期，现在通用的证书一般采用UTC时间格式，它的计时范围为1950-2049；
- 证书所有人的名称，命名规则一般采用X.500格式；
- 证书所有人的公开密钥；
- 证书发行者对证书的签名。

CA. 用公钥验证签名.

CA. / 用自己私钥签名.

权威机构给我签名，为何？

密钥管理技术




证书
常规
详细信息
证书路径
证书信息
这个证书的目的如下:
• 向远程计算机证明你的身份
• 保证远程计算机的身份
• 2.23.140.1.2.1
* 有关详细信息，请参考证书颁发机构的说明。
颁发给: *.xisaiwang.com
颁发者: RapidSSL TLS DV RSA Mixed SHA256 2020 CA-1
有效期从 2021-11-23 到 2022-11-24
颁发者说明(S)
确定


证书
常规
详细信息
证书路径
显示(S): <所有>
字段
值
版本 V3
序列号 02e38d824568aa7e...
签名算法 sha256RSA
签名哈希算法 sha256
颁发者 RapidSSL TLS DV RS...
有效期从 2021年11月23日 8:0...
到 2022年11月24日 7:5...
使用者 *.xisaiwang.com
公钥 RSA (2048 Bits)
30 82 01 0a 02 82 01 01 00 b6 d5 17 55 32 ec 58 9e e1 7b 45 9d b6 85
11 0b 53 38 d2 4b f1 2d 6d ae 3d 99 07 49 86 1e 24 b2 6f 49 5c bf 9a 3f
1a 1a a1 2a 76 49 05 96 dc ff fa d9 37 ed 88 c6 d7 3e 49 e3 cf 20 d1 f4
81 46 cb 2e 1b 8e 0a a7 16 2f e8 f9 b2 21 6d e2 92 20 01 45 cc cf 47 69
70 ca c8 7d 9f 59 06 59 ae 74 aa 8b 6c 03 72 d5 10 97 66 17 47 47 71 5d
74 54 ee 50 e7 70 79 cd 05 42 49 61 8c 4d 8f 58 8c f8 79 e7 ef f3 c2 be
99 7b 12 03 60 5e 87 e7 5a 25 69 4f f0 03 28 e1 a2 43 da 5a 8e 50 73 3b
02 ad 87 51 c0 25 28 09 7d a9 0c 17 59 3e 9e 5f f4 20 d1 7e f1 b9 1e 3e
86 f4 b7 70 68 27 ac 7c d4 7e 83 2f 5a 65 80 c1 bb 97 03 48 fa 07 09 82
编辑属性(E)...
复制到文件(C)...
确定



密钥管理技术

希赛

PKI公钥体系

- CA（Certificate Authority）

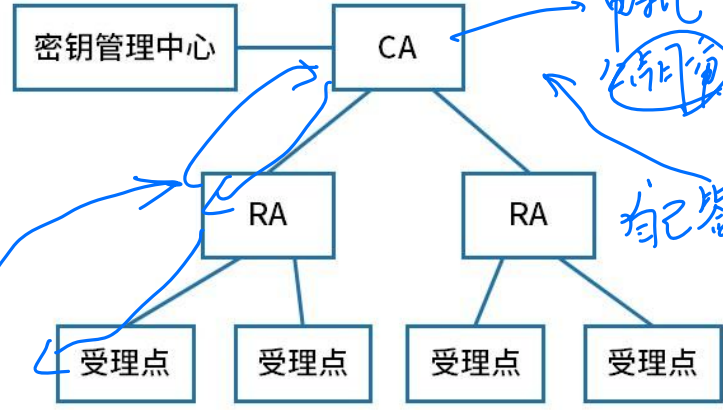
  认证中心

- RA（Registration Authority）

  注册审批机构

- 证书受理点

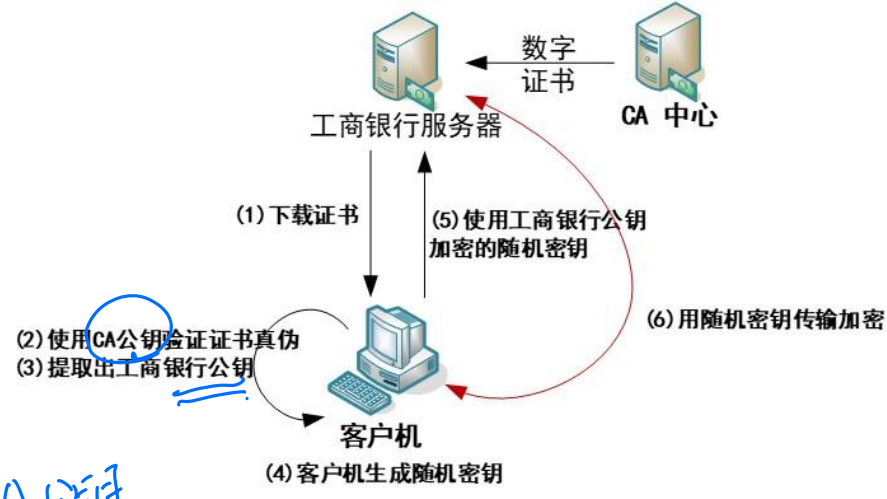
- 密钥管理中心-KMC





密钥管理技术

希赛

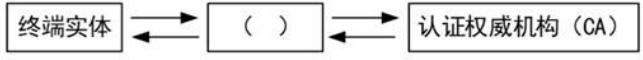


CA公钥.



习题讲解

公钥基础设施（Public Key Infrastructure,PKI）引入数字证书的概念，用来表示用户的身份。下图简要地描述了终端实体（用户）从认证权威机构CA申请、撤销和更新数字证书的流程。请为中间框空白处选择合适的选项（ ）。



A.证书库

B.RA

C.OCSP

D.CRL库

RA

注册审批机构.



习题讲解

希赛

在PKI体系中，注册机构RA的功能不包括（ ）。

A. 签发证书　　B. 认证注册信息的合法性

C. 批准证书的申请　　D. 拒绝证书的申请

某Web网站向CA申请了数字证书。用户登录过程中可通过验证（ ），确认该数字证书的有效性，以（ ）。

A. CA的签名　　B. 网站的签名　　C. 会话密钥　　D. DES密码

A. 向网站确认自己的身份　　B. 获取访问网站的权限

C. 和网站进行双向认证　　D. 验证该网站的真伪



信息安全的保障体系

希赛

◆ 计算机信息系统安全保护等级

计算机信息系统安全保护等级划分准则（GB 17859-1999）

- ✓ **用户自主保护级**：适用于普通内联网用户

  系统被破坏后，对公民、法人和其他组织权益有损害，但不损害国家安全社会秩序和公共利益。

- ✓ **系统审计保护级**：适用于通过内联网或国际网进行商务活动，需要保密的非重要单位

  系统被破坏后，对公民、法人和其他组织权益有严重损害，或损害社会秩序和公共利益，但不损害国家安全。

- ✓ **安全标记保护级**：适用于地方各级国家机关、金融机构、邮电通信、能源与水源供给部门、交通运输、大型工商与信息技术企业、重点工程建设等单位

  系统被破坏后，对社会秩序和公共利益造成严重损害，或对国家安全造成损害。

- ✓ **结构化保护级**：适用于中央级国家机关、广播电视部门、重要物资储备单位、社会应急服务部门、尖端科技企业集团、国家重点科研机构和国防建设等部门

  系统被破坏后，对社会秩序和公共利益造成特别严重损害，或对国家安全造成严重损害。

- ✓ **访问验证保护级**：适用于国防关键部门和依法需要对计算机信息系统实施特殊隔离的单位

  系统被破坏后，对国家安全造成特别严重损害。



信息安全的保障体系

希赛

- 计算机信息系统安全保护等级

	公民、法人和其他组织权益	社会秩序和公共利益	国家安全
用户自主保护级	损害		
系统审计保护级	严重损害	损害	
安全标记保护级		严重损害	损害
结构化保护级			严重损害
访问验证保护级			特别严重损害



习题讲解

依据国家信息安全等级保护相关标准，军用不对外公开的信息系统的安全等级至少应该属于（ ）。

A．二级及二级以上　　B．三级及三级以上

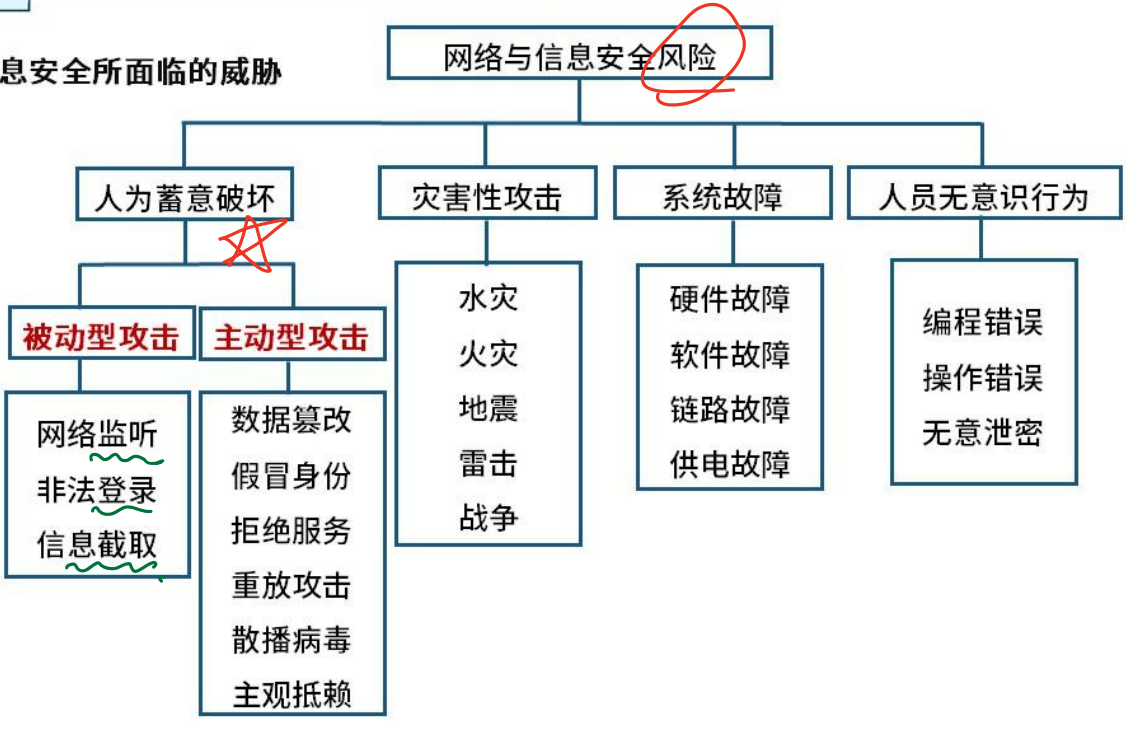
C．四级及四级以上　　D．五级



安全架构概述

希赛

- 信息安全所面临的威胁





安全架构概述

希赛

被动攻击：**收集信息为主**，破坏保密性。

主动攻击：主动攻击的类别主要有：中断（破坏可用性），篡改（破坏完整性），伪造（破坏真实性）。

攻击类型	攻击名称	描述
被动攻击	窃听（网络监听）	用各种可能的合法或非法的手段窃取系统中的信息资源和敏感信息。
	业务流分析	通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。
	非法登录	有些资料将这种方式归为被动攻击方式。



安全架构概述

希赛

攻击类型	攻击名称	描述
主动攻击	假冒身份	非法用户冒充成为合法用户，特权小的用户冒充成为特权大的用户。
	抵赖	否认自己曾经发布过的某条消息、伪造一份对方来信等。
	旁路控制【旁路攻击】	密码学中是指绕过对加密算法的繁琐分析，利用密码算法的硬件实现的运算中泄露的信息。如执行时间、功耗、电磁辐射等，结合统计理论快速的破解密码系统。
	重放攻击	所截获的某次合法的通信数据拷贝，出于非法的目的而被重新发送。加【时间戳】能识别并应对重放攻击。
	拒绝服务（DOS）	破坏服务的【可用性】，对信息或其他资源的合法访问被无条件的阻止。



安全架构概述

希赛

攻击类型	攻击名称	描述
主动攻击	XSS跨站脚本攻击	通过利用网页【开发时留下的漏洞】，通过巧妙的方法注入恶意指令代码到网页
	CSRF跨站请求伪造攻击	攻击者通过一些技术手段欺骗用户的浏览器与访问一个自己曾经认证过的网站并执行一些操作（如转账或购买商品等）。
	缓冲区溢出攻击	利用【缓冲区溢出漏洞】所进行的攻击。在各种操作系统、应用软件中广泛存在。
	SQL注入攻击	攻击者把SQL命令插入到Web表单，欺骗服务器执行恶意的SQL命令。 SQL注入攻击的方式：【恶意拼接查询】、【利用注释执行非法命令】、【传入非法参数】、【添加额外条件】 抵御SQL攻击的方式包括：【使用正则表达式】、【使用参数化的过滤性语句】、【检查用户输入的合法性】、【用户相关数据加密处理】、【存储过程来执行查询】、【使用专业的漏洞扫描工具】



习题讲解

希赛

以下网络攻击中，（ ）属于被动攻击。

A. 拒绝服务攻击

B. 重放

C. 假冒

D. 网络监听



习题讲解

信息系统面临多种类型的网络安全威胁。其中，信息泄露是指信息被泄露或透露给某个非授权的实体；（ ）是指数据被非授权地进行修改；（ ）是指对信息或其他资源的合法访问被无条件地阻止；（ ）是指通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。

A. 非法使用　　B. 破坏信息的完整性　　C. 授权侵犯　　D. 计算机病毒

A. 拒绝服务　　B. 陷阱门　　C. 旁路控制　　D. 业务欺骗

A. 特洛伊木马　　B. 业务欺骗　　C. 物理侵入　　D. 业务流分析



安全模型

希赛

- 安全模型的分类

基本模型：HRU

- 机密性
  - 访问控制
    - MAC强制
      - BLP
      - Chinese Wall
    - DAC自主
    - RBAC角色
  - 信息流
- 完整性
  - Biba
  - Clark-Wilson



安全模型

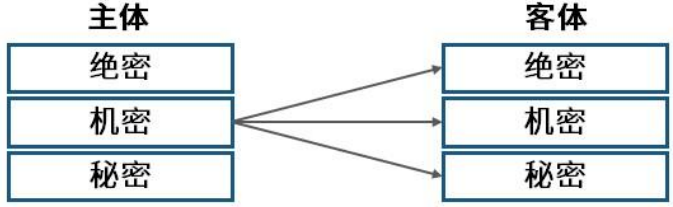
希赛

BLP模型

Bell-LaPadula模型是符合军事安全策略的计算机安全模型，简称BLP模型。

BLP模型的安全规则如下：

- 简单安全规则：安全级别**低**的主体**不能**读安全级别**高**的客体；
- 星属性安全规则：安全级别**高**的主体**不能**往**低**级别的客体写；
- 强星属性安全规则：**不允许**对**另一级别**进行读写；
- 自主安全规则：使用**访问控制矩阵**来定义说明自由存取控制。





安全模型

希赛

◆ Biba模型

BiBa模型主要用于防止非授权修改系统信息，以保护系统的信息完整性。该模型同BLP模型类似，采用主体、客体、完整性级别描述安全策略要求。BiBa模型能够防止数据从低完整性级别流向高完整性级别，其安全规则如下：

- 星完整性规则：表示完整性级别**低**的主体**不能**对完整性级别**高**的客体写数据；
- 简单完整性规则：表示完整性级别**高**的主体**不能**从完整性级别**低**的客体读取数据；
- 调用属性规则：表示一个完整性级别**低**的主体**不能**从级别**高**的客体调用程序或服务。





安全模型

希赛

◆ Chinese Wall模型

Chinese Wall模型的安全策略的基础是客户访问的信息不会与当前他们可支配的信息产生冲突。

其访问客体控制的安全规则如下：

- 与主体曾经访问过的信息属于**同一公司数据集合**的信息，即**墙内信息**可以访问；
- 属于一个**完全不同**的利益冲突组的可以访问；
- 主体能够对一个客体进行写的前提是主体**未对**任何**属于其他公司数据集**进行过访问。

定理1：一个主体一旦访问过一个客体，则该主体**只能**访问位于**同一公司数据集**的客体或在**不同利益组**的客体。

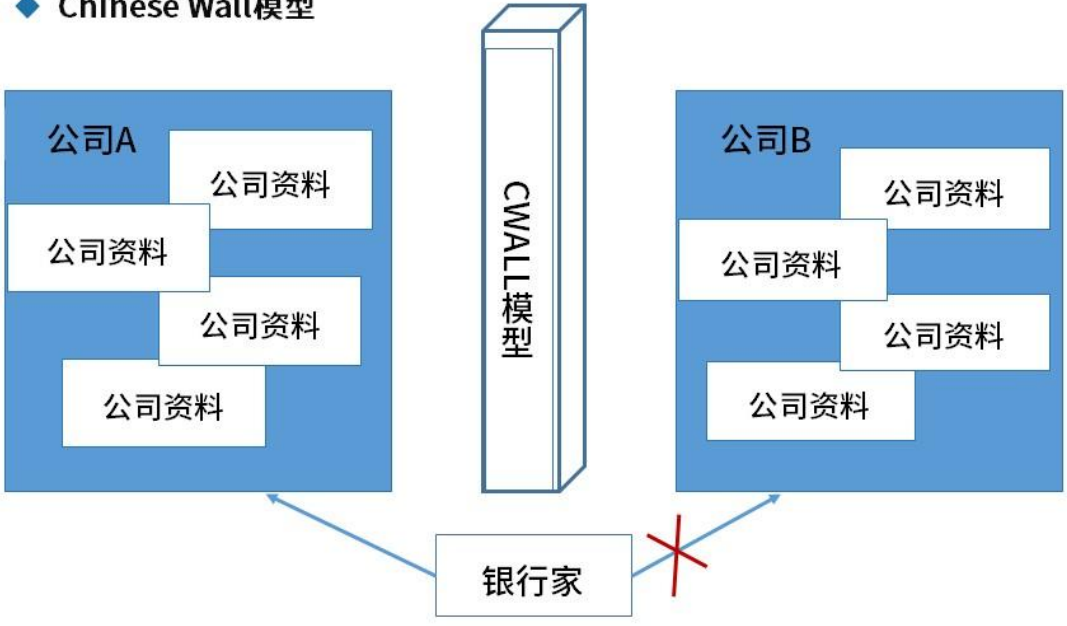
定理2：在**一个利益冲突组**中，一个主体**最多只能**访问**一个公司数据集**。



安全模型

希赛

- Chinese Wall模型





习题讲解

希赛

Biba模型是属于（ ）。

A. 状态机模型　　B. 信息流模型

C. 无干扰模型　　D. 完整性模型

BLP模型的设计目标是解决信息系统资源的（ ）保护。

A. 不可否认性　　B. 机密性

C. 完整性　　D. 匿名性



习题讲解

希赛

Bell-LaPadual模型（简称BLP模型）是最早的一种安全模型，也是最著名的多级安全策略模型，BLP模型的简单安全规则是指（ ）。

A. 不可上读　　B. 不可上写

C. 不可下读　　D. 不可下写



信息安全整体架构设计

希赛

◆ WPDRRC模型

WPDRRC模型包括**6个环节**和**3大要素**。

6个环节包括：预警、保护、检测、响应、恢复和反击。模型蕴涵的网络安全能力主要是预警能力、保护能力、检测能力、响应能力、恢复能力和反击能力。

3大要素包括人员、策略和技术。



信息安全整体架构设计

希赛

◆ 各模型安全防范功能

	预警	保护	检测	响应	恢复	反击	管理
PDR	无	有	有	有	无	无	无
PPDR	无	有	有	有	无	无	无
PDRR	无	有	有	有	有	无	无
MPDRR	无	有	有	有	有	无	有
WPDRRC	有	有	有	有	有	有	有



习题讲解

希赛

P2DR模型不包括（　）。

A．防护　　B．检测

C．响应　　D．预警

加密机制、数据签名机制、访问控制机制、认证机制、信息隐藏、防火墙技术等是属于WPDRRC模型中（　）环节。

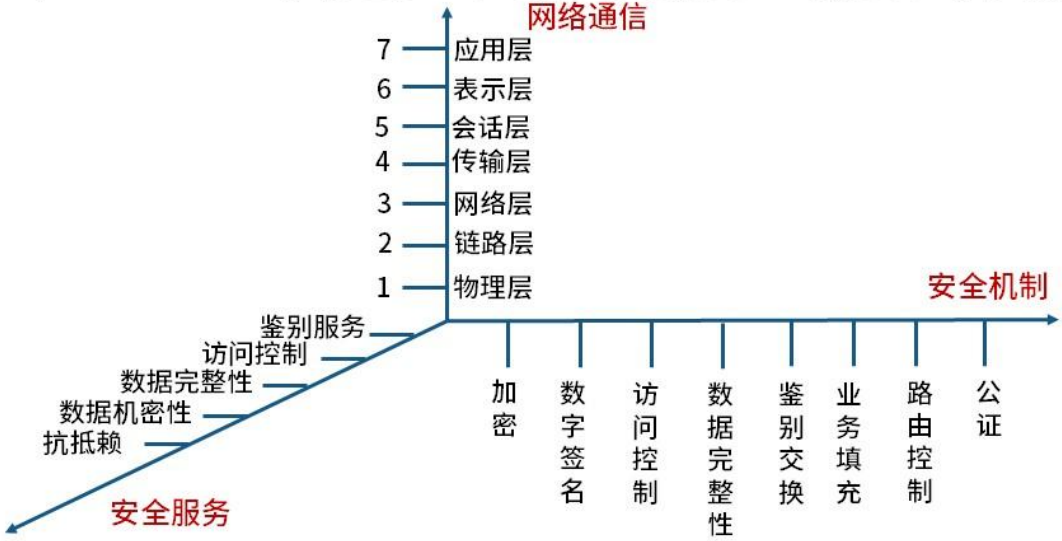
A．保护　　B．检测

C．响应　　D．恢复

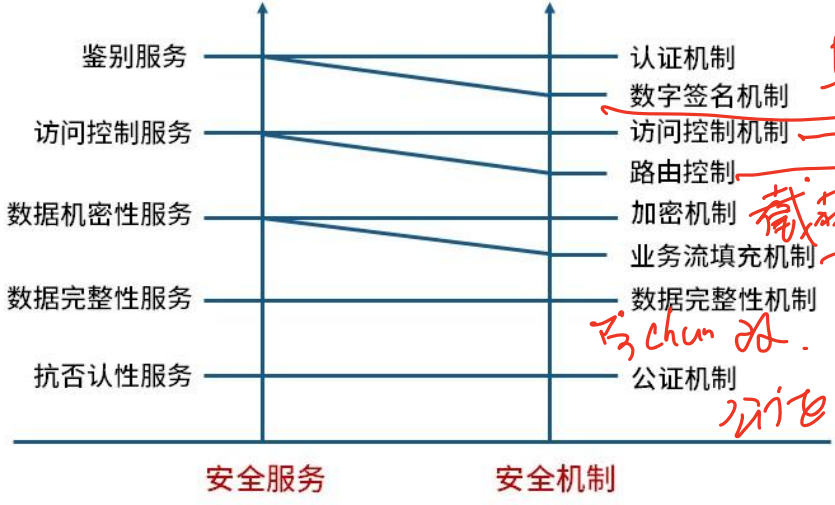
希赛

◆ **开放系统互联安全体系结构**

GB/T 9387.2－1995给出了基于OSI参考模型的7层协议之上的信息安全体系结构。



- 安全服务与安全机制的对应关系



◆ **认证框架**

鉴别的基本目的是防止其他实体占用和独立操作被鉴别实体的身份。

鉴别的方式如下：

（1）已知的；（2）拥有的；（3）不改变的特性；（4）相信可靠的第3方建立的鉴别；（5）环境。

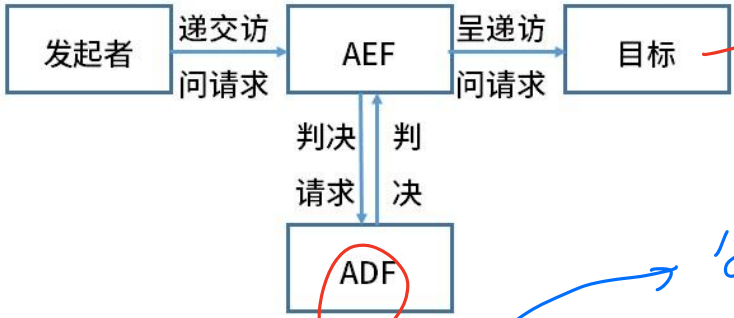
鉴别信息的类型包括交换鉴别信息、申请鉴别信息和验证鉴别信息。



- **访问控制框架**

访问控制决定开发系统环境中允许使用哪些资源，在什么地方适合阻止未授权访问的过程。

基本访问控制功能示意图



◆ **机密性框架**

机密性服务的目的是确保信息仅仅是对被授权者可用。

机密性机制：

（1）通过**禁止访问**提供机密性；

（2）通过**加密**提供机密性。

◆ **完整性框架**

完整性框架的目的是通过阻止威胁或探测威胁，保护可能遭到不同方式危害的数据完整性和数据相关属性完整性。

完整性机制的类型：

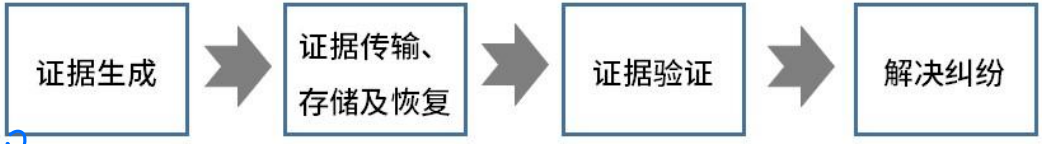
（1）**阻止对媒体访问**的机制；

（2）用以**探测对数据或数据项序列的非授权修改**的机制。

◆ **抗抵赖框架**

抗抵赖服务包括证据的生成，验证和记录，以及在解决纠纷时随即进行的证据恢复和再次验证。

抗抵赖由4个独立的阶段组成：





习题讲解

保护信息不泄露或不暴露给那些未授权想掌握该信息的实体是（ ）安全服务。

A．鉴别　　B．数据完整性

C．数据机密性　　D．访问控制

门禁卡是属于以下哪种鉴别方式？（ ）

A．已知的　　B．拥有的

C．不改变的特性　　D．环境



区块链技术

希赛

【什么是区块链】

【区块链】 ≠ 比特币

比特币底层采用了区块链技术。

比特币交易在我国定性为【非法运用】。



区块链技术

希赛

【区块链的特点】

去中心化：由于使用分布式核算和存储，不存在中心化的硬件或管理机构，任意节点的权利和义务都是均等的，系统中的数据块由整个系统中具有维护功能的节点来共同维护。

开放性：系统是开放的，如：区块链上的【交易信息是公开的】，不过【账户身份信息是高度加密的】。

自治性：区块链采用基于协商一致的规范和协议（比如一套公开透明的算法）使得整个系统中的所有节点能够在去信任的环境自由安全的交换数据，使得对“人”的信任改成了对机器的信任，任何人为的干预不起作用。

安全性（信息不可篡改）：数据在多个结点存储了多份，篡改数据得改掉51%结点的数据，这太难。同时，还有其它安全机制，如：比特币的每笔交易，都由付款人用私钥签名，证明确实是他同意向某人付款，其它人无法伪造。

匿名性（去信任）：由于节点之间的交换遵循固定的算法，其数据交互是无需信任的（区块链中的程序规则会自行判断活动是否有效），因此交易对手无须通过公开身份的方式让对方自己产生信任，对信用的累积非常有帮助。

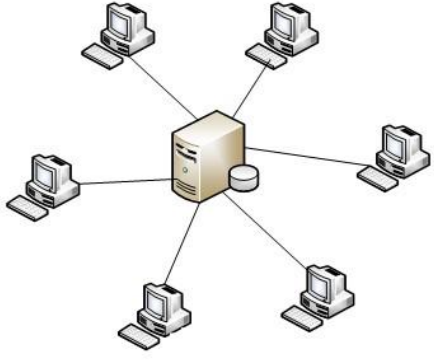


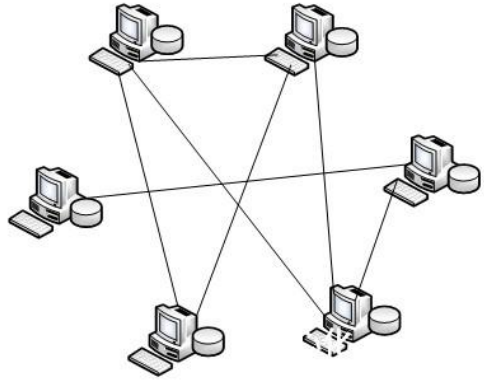
区块链技术

希赛

【去中心化】

区块链是一个分布式账本，一种特殊的分布式数据库。





1、链表在多个结点存储，没有中心结点，数据不一致时，以“少数服从多数”原则执行。

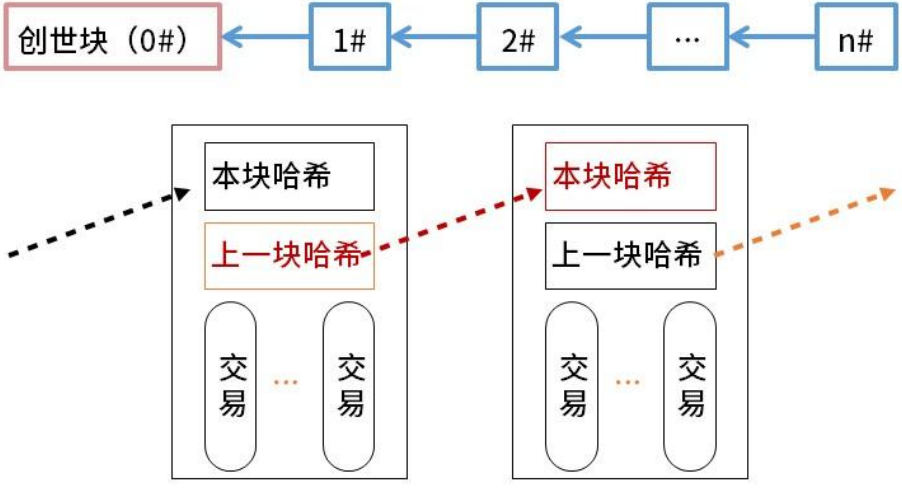
2、所以要篡改成功，除非篡改51%的结点。



区块链技术

希赛

【哈希加密/防篡改】





区块链技术

希赛

【共识算法(博弈论)/全民记账】

一般有：POW（工作量证明）、PoS（权益证明）、DPoS（股份授权证明机制）

比特币采用了POW（工作量证明）：
争夺记账权 = 挖矿

计算出来的账单结点哈希值前13个字符为0，则符合规则，得到记账权。
有一个结点计算出结果，则广播消息告知其它结点，其它结点更新数据。

计算困难，但验证却很容易，例如：
218903 = 哪两个质数的乘积？

457*479



习题讲解

希赛

以下关于区块链应用系统中“挖矿”行为的描述中，错误的是（ ）。

A. 矿工“挖矿”取得区块链的记账权，同时获得代币奖励

B. “挖矿”本质上是在尝试计算一个Hash碰撞

C. “挖矿”是一种工作量证明机制

D. 可以防止比特币的双花攻击

一份钱花两次.